Remediation Plan

TRACEGUARD | Evidence snapshot

Schema Version
1.0

Bundle Id
dbbaf1ae-0df5-42d5-b813-ff93aaa30f84

Generated At
2026-10-31T22:13:33.668Z

Scan

Id
96319e99-6acb-4611-a50b-878432906541

Source
OFFLINE DEMO ? simulated external evidence ? ZIP upload

Created At
2026-10-31T22:13:33.378Z

Inventory Sha256
0ef4924823d675252f29e8df666bddd676ceba93e9e522fcbe503d2983ff21e8

Coverage

Status
complete

Checked At
2026-10-31T22:13:33.668Z

Package Instances
1

Matched
1

No Known Match
0

Unknown
0

Findings Included
1

Findings Omitted
0

Limitations

1.
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

2.
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

3.
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

4.
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

5.
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per finding are included. Descriptions, references, paths and source evidence are bounded.

6.

Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

7.
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

8.
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

9.
Transitive updates require changes to the owning dependency declaration or parent. No dependency graph or lockfile is changed automatically.

10.
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

11.
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

Report Type
remediation-plan

Title
Remediation Plan

Actions

1.

Finding Id
F-001

Package Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Package Name
lodash

Installed Version
4.17.20

Status
VERIFIED CANDIDATE

Suggested Version
4.17.21

Verification

Checked At
2026-10-31T22:13:33.668Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-DEMO-0001

Registry Source
https://registry.npmjs.org/lodash/4.17.21

Candidate Advisory Status
no-known

Compatibility
NOT TESTED

Steps

1.
Review the cited advisories and release notes for lodash 4.17.21; compare with installed 4.17.20. Compatibility has not been tested.

2.
In package-lock.json, locate the owning package.json declaration (including aliases) and update its declared dependency to the verified candidate 4.17.21. Preserve the intended runtime/dev/optional role.

3.
Regenerate the affected lockfile in your controlled development environment, review the diff, and ensure every affected installation path is replaced. Do not edit a nested node_modules copy as the fix.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-DEMO-0001

2.
https://docs.npmjs.com/cli/v11/commands/npm-install/

3.
https://docs.npmjs.com/cli/v11/configuring-npm/package-json/#overrides

4.
https://docs.npmjs.com/cli/v11/commands/npm-explain/

Package Risk

Checked At
2026-10-31T22:13:33.668Z

Coverage

Total
1

Metadata Checked
1

Unavailable
0

Skipped
0

Results

1.

Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures
(none recorded)

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/lodash/4.17.20

Metadata

Description
SIMULATED registry metadata for offline demonstration

License

Maintainers
(none recorded)

Lifecycle Scripts

Limitations

1.
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

2.
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

3.
At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

4.
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

5.
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

6.
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

Sources

1.
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

2.
https://docs.npmjs.com/viewing-package-provenance/

3.
https://docs.npmjs.com/cli/v11/commands/npm-audit/

4.
https://osv.dev/

Coverage Actions

1.
Validate changes in a trusted development environment. TRACEGUARD does not execute fixes or submitted source code.